TECHNICAL DOCUMENT

Security Architecture

5-Layer Defense-in-Depth System

Executive Summary

Chitragupta handles sensitive legal data — FIR reports, case files, personal identification, and lawyer-client communications. A breach doesn't just expose data; it puts vulnerable people at risk. Our security architecture reflects this responsibility with **5 distinct layers of protection**.

🪪 Layer 1 — Registration & Identity

6-digit OTP via Email + SMS on signup • 10-min expiry • Password strength enforcement • Email/phone verification • Account lockout after 5 failed attempts

🔐 Layer 2 — Authentication

JWT access tokens (15 min) + refresh tokens (7 days) with rotation • Admin TOTP 2FA via Google Authenticator • 10 hashed backup recovery codes • Device fingerprinting

2

🛡️ Layer 3 — Runtime Protection

WAF middleware scanning for XSS, SQLi, path traversal • IP + user rate limiting via Redis • CORS lockdown • Helmet security headers • HPP protection • 10kb body limit

3

📊 Layer 4 — Activity Monitoring

Winston → PostgreSQL immutable audit logs (append-only) • Push notifications for new device login, document access, suspicious activity • CSV/PDF export

4

🔍 Layer 5 — Vulnerability Scanner

Automated scheduled self-scan of all endpoints • CVSS scoring (Critical/High/Medium/Low) • AI-generated reports • Admin dashboard visualization

5

Request Processing Pipeline

🌐 Request → Helmet → CORS → Body Parser → HPP → WAF Scan →
Rate Limit → JWT Auth → Handler → Audit Log → 📤 Response

Audit Events Tracked

EVENT	SEVERITY	TRIGGER
User Login	ℹ️ Info	Successful authentication
Failed Login	⚠️ Warning	Wrong password
New Device Login	⚠️ Warning	Unknown device fingerprint
Document Accessed	ℹ️ Info	Lawyer views case file
Settings Changed	⚠️ Warning	Admin modifies configuration
SQL Injection Attempt	🚨 Critical	WAF detects malicious payload
Account Locked	🚨 Critical	5+ failed login attempts
TOTP Verification	ℹ️ Info	Admin 2FA check

Database Security

```
-- Audit logs are append-only (tamper-evident)
REVOKE UPDATE, DELETE, TRUNCATE ON audit_logs FROM PUBLIC;

-- Passwords: bcrypt hashed (salt rounds = 12)
-- Backup codes: bcrypt hashed
-- Refresh tokens: SHA-256 hashed
-- 8 production tables with UUID primary keys
-- Performance indexes on all foreign keys
```

Compliance Alignment

OWASP Top 10

XSS (A7), SQLi (A1), Broken Auth (A2), Security Misconfiguration (A5)

IT Act 2000 (India)

Section 43A — Reasonable Security Practices for sensitive personal data

GDPR Principles

Data minimization, audit trail, access logging, right to be informed

DISHA (India)

Digital health data protection alignment for sensitive legal records

---